Laboratorio 6.1: Phishing con SET y Metasploit

En el laboratorio actual usted aplicará los conocimientos adquiridos en el capítulo de Hacking para demostrar lo fácil que es ejecutar un ataque de Phishing y ejecutar un Troyano (shell reverso embebido en un Applet de Java) con ayuda de las herramientas SET y Metasploit incluidas en la distribución Backtrack Linux.

Nota: *Para la ejecución del laboratorio se requiere dos PC's, una que hará las veces de Hacker en donde se ejecutará Backtrack Linux y un segundo PC con Windows XP que hará las veces de Víctima. Este laboratorio ha sido realizado con fines educativos solamente, Elixircorp no se responsabiliza por el uso que los alumnos puedan darle a este conocimiento.*

1. Bootee el PC del Hacker desde Backtrack y ejecute la interfaz gráfica con el comando *startx*.
2. Si se le solicita realizar un *logon* utilice las siguientes credenciales:

   `Username: root`

   `Clave: toor`

3. Desde el menú de Aplicaciones, escoja el aplicativo *set* (Social Engineering Toolkit):

Ilustración 1 – Ejecutamos set (Social Engineering Toolkit)

4. El ataque que vamos a realizar involucra vectores de ataque de Sitios Web (Web Site Attack Vectors, opción 2)

Ilustración 2 - Selección de Ataque basado en Web

5. Hay varios métodos de ataques web, pero para este laboratorio vamos a ilustrar uno muy sencillo que incluye inyectar código malicioso en un Applet de Java (The Java Applet Attack Method, opción 1).

Ilustración 3 - Ataque haciendo uso de un Java Applet

6. Ahora nos corresponde escoger qué página web le vamos a presentar a las víctimas que se conecten a nuestro sitio malicioso. Hay varias opciones, podemos usar una plantilla preestablecida de sitios webs conocidos como Facebook, Google, etc. O mejor aún podemos clonar un sitio web de nuestra elección.
7. En esta ocasión vamos a escoger un sitio web mundialmente conocido como Facebook, por eso elegiremos la opción de clonación (Site Cloner, opción 2).

Ilustración 4 - Opción para clonar un sitio web

8. Posteriormente elegimos el código malicioso que se ejecutará en el momento en que el usuario ingrese al sitio web clonado y acepte el Applet de Java. Hay diferentes opciones, pero al momento elegiremos la opción 2, la cual consiste en que se abrirá un shell reverso (para acceder con la herramienta Meterpreter de Metasploit) desde la máquina víctima hacia nuestro equipo (el del hacker).

Ilustración 5 - Shell reverso de Meterpreter como payload

9. Finalmente escogemos la opción de codificación de nuestro payload (el código que llevará el Applet) para evitar que sea detectado fácilmente por un antirus. Existen diferentes tipos de codificaciones, pero en este ejemplo usaremos Multi-Encoder (opción 15) el cual realiza el proceso de codificación varias veces seguidas. Adicionalmente elegimos un número de puerto libre por el que escucharemos en Meterpreter las sesiones que abran nuestras "víctimas".

Ilustración 6 - Codificación del payload con Multi-Encoder

10. Posteriormente tenemos la opción de hacer que el ataque funcione también sobre ambientes Linux. Debido a que en este laboratorio la "víctima" es un PC con Windows XP, seleccionaremos la opción No, para hacer el payload más pequeño.
11. El aplicativo SET se encarga de iniciar automáticamente la consola de Metasploit y de abrir la herramienta Meterpreter por nosotros. En este momento nuestro website malicioso está activo y a la espera de conexiones procedentes de nuestras "víctimas".

Ilustración 7 - Website clonado listo y Meterpreter a la espera de conexiones

12. Ahora podremos utilizar cualquier medio de ingeniería social para dirigir a las "víctimas" a nuestro website malicioso. Para efectos de laboratorio, asumiremos que el usuario del PC con Windows XP recibió un mail falso (Phishing) del servicio de notificaciones de Facebook e hizo click en un link embebido que lo redirige a nuestro sitio web.

Ilustración 8 - Mail falso suplantando al servicio de notificaciones de Facebook

13. Luego de hacer click sobre el enlace nuestro ingenuo amigo es redireccionado al sitio web clonado. Este es un claro ejemplo de lo peligroso que puede ser el Phishing. Si un hacker desea hacer más realista el ataque podría comprar un nombre de dominio parecido al del sitio web clonado. Para que el ataque tenga éxito el usuario debe hacer click en el botón Ejecutar.

Ilustración 9 - Nuestro Applet solicita confirmación del usuario

14. Después de hacer click en Ejecutar el usuario es redirigido al verdadero website de Facebook. Paralelamente nuestro payload abre una sesión remota hacia el puerto de escucha en la máquina del hacker que definimos previamente. Para el usuario es transparente, pero en la máquina del hacker nos muestra una notificación de que hay una nueva sesión en Meterpreter.

Ilustración 10 - Tomamos control de la sesión de la víctima

15. Para tomar el control de la sesión ejecutamos el comando `sessions -i #` en donde # representa el número de la sesión, para este ejemplo "1". Y una vez que hemos tomado control de la sesión podemos realizar lo que queramos con el PC víctima, como abrir una línea de comandos, capturar la pantalla, leer, copiar, borrar archivos, tomar control de la cámara y tomarle una foto a la víctima, activar el micrófono de la víctima y escuchar lo que se habla alrededor del PC, etc.
16. Verifique la ayuda de Meterpreter con el comando `help` para que pruebe las diferentes opciones posibles y si tiene alguna duda por favor consulte con su instructor.